

RG 全体講義: プロトコル設計における脅威の明確化と正当性証明

moz@sfc.wide.ad.jp

April 30, 2025

主題

- ・ プロトコルの設計について紹介する
- ・ 脅威モデルについて紹介する
- ・ プロトコルの正当性証明 (Formal Proof) について紹介する
- ・ 最後に Delight 的な (分散システムとデジタルアイデンティティについての) 研究課題を紹介する

目的

- ・ 分散システムにおけるプロトコルの設計 (のお気持ち) を理解する
- ・ プロトコルの設計における正当性保証の考え方 (のお気持ち) を理解する
- ・ 自身のプロトコルを学術論文としてまとめる際、どのような構成で何を明らかにすれば良いかを理解する

プロトコルとは？

プロトコルの定義 (Oxford Dictionary)

A set of rules governing the exchange or transmission of data between entities.

エンティティ：プロトコルに参加する個々の主体（ユーザー、デバイス）を指す。

アルゴリズムの定義 (Oxford Dictionary)

A set of instructions for performing a task or solving a problem.

アルゴリズムは計算手順に焦点を当てるのに対し、プロトコルは参加者間の相互作用に重点を置く。¹一般的なプロトコルの例：HTTP、SMTP、TLS/SSL、SSH、OAuth、Paxos、Raft

¹プロトコルは英語や日本語など共通のルールで会話する例として説明されることが多いが、これは相互作用の規則を表しているためである。一方で「日本語アルゴリズム」という表現が一般的でないのは、アルゴリズムが相互作用ではなく計算手順を表すためである。

正当 (Correctness) なプロトコルの設計をどうやるか

この講義はプロトコルの設計手法については紹介しない。

皆さんが自分のドメインで設計したプロトコルがなぜ正当 (Correctness) と言えるのかをどのように他人に説明できるかを考える講義

プロトコルの正当性を示すには、以下の点を明確にすることが重要である：

- ・ どのようなエンティティがプロトコルに関与するか
- ・ エンティティ間でどのような情報交換が行われるか
- ・ プロトコルはどのような条件を満たせば安全であると言えるのか
- ・ それぞれのエンティティがどのような振る舞いをする可能性があるか
- ・ そのようなエンティティが存在するときに、プロトコルが正当²であるかどうかをどのように判断するか

²Safety (悪いことが起こらない) , Liveness (良いことがいつか起こる) のプロパティを共に満たすか

敵対者と脅威モデル

プロトコル設計において、どのような振る舞いを許容するかを考える上では、エンティティの能力と行動に関する仮定を明確にすることが重要である。

敵対者

An adversary refers to an attacker, typically with malicious intent, who undertakes actions against a system or protocol

敵対者は、プロトコルに参加するエンティティを制御下に置き、そのエンティティの動作を変更または監視できる状態。

脅威モデル

脅威モデル (threat model) とは、敵対者の能力と行動に関する仮定を形式化したモデル。



脅威モデルの構成要素

脅威モデルは以下の5つの要素から構成から構成される：

1. Corruption Model. 敵対者が制御するエンティティの行動様式
2. Computational Power. 敵対者が利用できる計算リソースの制約
3. Adaptivity. 敵対者がエンティティを腐敗させるタイミングと方法
4. Visibility. 敵対者が観察できる情報の範囲
5. Mobility. 敵対者によるエンティティの腐敗と回復のパターン

この要素の組み合わせ方によって、異なる脅威モデルが定義される。どのような要素を選択するかは、プロトコルの目的、実行されうる環境によって決まる。

腐敗モデル (Corruption Models)

腐敗モデルは、敵対者はエンティティをどのように制御できるかを定義する。

- ・ Passive. プロトコルに完全に従いながら、観測したすべての情報を蓄積して活用できる。しかし、プロトコルの仕様に逸脱することはできない。³⁴
- ・ Crash. 応答を任意のタイミングで停止できるが、停止時間外は正確にプロトコルに従って動作する。
- ・ Omission. エンティティは受信したのメッセージを任意に削除または無視できる。送信するメッセージの内容を変更することはできない。
- ・ Byzantine. エンティティはプロトコル仕様から任意に逸脱できる。

各モデルは前のモデルを包含している：Byzantine $\supset$ Omission $\supset$ Crash $\supset$ Passive

³具体例として銀行の従業員、顧客の取引データを正しく処理しながらも、そのデータをこっそり記録して個人的に利用する場合。

⁴Honest-but-Curious, Semi-Honest モデルとも呼ばれる。

適応性モデル (Adaptivity Models)

適応性モデルは、敵対者がいつ、どのように参加者を腐敗させるかを定義する：

- ・ Static：敵対者は腐敗させるエンティティをプロトコル実行前に選ぶ。実行中に変更できない。
- ・ **Adaptive**：敵対者はプロトコル実行中に腐敗させるエンティティを動的に選択できる。

エンティティが少ない場合、プロトコルの通信フェーズ数が多い場合、プロトコルの実行時間が長い場合、Adaptive モデルを考慮する。例えば、鍵交換モデルなどでは、Static モデルを考えることが一般的。コンセンサスアルゴリズムでは、Adaptive モデルを考えることが一般的。

可視性モデル (Visibility Models)

可視性モデルは、敵対者がどの程度のメッセージや内部状態を観察できるかを定義する。

- ・ Full Information. 敵対者はすべてのメッセージ内容と各エンティティの内部状態（実行中の変数）を完全に観察可能
- ・ Private Channels. 正直なエンティティ間の通信内容は敵対者から隠されるが、通信の発生事実やメタデータ（送信元、宛先、タイミング、メッセージサイズ等）は観察可能。腐敗したエンティティの状態、メッセージ内容は観察可能。
- ・ Erasure Model. Private Channels に対して、参加者が腐敗する前に消去されたデータは、敵対者は観察・復元できない制約を足したもの。
- ・ Oblivious. メッセージのヘッダー情報（送信元、宛先、長さ）のみを観察可能で、内容は完全に隠蔽される。⁵

暗号プロトコルでは、機密性 (intended to be kept secret) を保証するために、Private Channels モデルを考えることが多い。

⁵Trusted Computing のようなシステムでは、このモデルを考えることが多い。

計算能力モデル (Computational Power Models)

計算能力モデルは、敵対者の計算資源の制限を定義する：

- ・ Unbounded. 無制限の計算資源を持つ敵対者。理論上はすべての暗号を破ることができる。
- ・ Polynomially Bounded. 多項式時間の計算⁶に制限される敵対者
- ・ Fine-grained. 特定の計算制限を持つ敵対者。
秒間ハッシュ計算回数に制限があるモデル (Hashrate)

重要なのは、エンティティの計算能力ではなく、敵対者の計算能力である。敵対者は Visibility Models にそって、エンティティのメッセージや内部状態を観察できる。その情報を敵対者はどのような計算資源を用いて活用できるかを定義する。

⁶ある問題 (Problem) を解くときに、その問題の解を求める計算複雑性がオーダー $O(n^c)$ $n, c \in \mathbb{Z}$ で表せる。
例えば、離散対数問題、素因数分解問題の難しさなど。

一般的には Probabilistic Polynomial Time (PPT) が確率チューリングマシンにおいて、入力となるセキュリティパラメータ $\lambda \in \mathbb{Z}$ (鍵長など) の大きさに対して、乱数を用いながらも 多項式時間 λ^c 以内に必ず終了するアルゴリズム

移動性モデル (Mobility Models)

移動性モデルは、敵対者による参加者の腐敗と回復のパターンを定義する：

- ・ Fixed. 一度腐敗したエンティティはプロトコル実行中ずっと腐敗したままであり、回復することはない
- ・ Mobile. 敵対者はエンティティを動的に腐敗させたり、回復させたりできる。ただし、任意の時点で腐敗しているエンティティの総数には上限がある⁷

IoT やモバイルデバイス、システムの長期運用の視点を考えると、一般的に Mobile モデルを考える。

⁷Adaptivity Models の Adaptive との混同に注意すること。Adaptive は敵対者がエンティティを腐敗させるタイミングを選択できることを指す。Mobility はその条件下において、一度腐敗させたエンティティが正常なエンティティとして回復するかどうかを考慮している。

適切な仮定を置くことの重要性

セキュリティプロトコルの研究において、**仮定の明確化**は極めて重要である。

- ・ 仮定が弱すぎる場合. 現実的な攻撃に対して脆弱なプロトコルになる可能性がある
- ・ 仮定が強すぎる場合. 設計や実装が複雑になり、その影響でパフォーマンスが下がり、実用性が低下する可能性がある

仮定を明示する価値：

- ・ **プロトコルの正当性**を正確に理解できる
- ・ 異なるプロトコルを同じ基準で公正に比較できる

実際のシステム設計では、特定の用途や発生しうるリスクに基づいて適切な仮定（脅威モデル）を選択することが重要である。

例：Practical Byzantine Fault Tolerance (PBFT)

PBFT

- ・ PBFT は、Byzantine 障害を許容しつつも、Linearizable⁸を達成するレプリケーションプロトコル⁹である。
- ・ ただし、 $n \geq 3f + 1$ （ここで f は敵対者の数、 n はレプリカの総数）のときに限る。

PBFT プロトコルは、非同期通信モデルにおいて初めて Linearizable を達成することを示したプロトコルである。発表から 20 年経った現在でも、PBFT は依然として広く使われている。

⁸Linearizable に複製するとは、すべてのレプリカが同じ順序でクライアント要求を処理し、その反映がクライアントの Read リクエストのセッション内で必ず行われる性質である。各複製データにはシーケンス番号が割り当てられ、このシーケンス番号に従って処理される。

⁹チューリング完全な状態マシンでは、複製されるデータをオペレーション（状態遷移関数）と見なす。オペレーション f, g がある場合、一般に $f \circ g \neq g \circ f \neq id$ であるため、実行順序が重要になる。

PBFT の主なフェーズ：

1. Pre-prepare：プライマリ（リーダー） p がクライアント要求 r にシーケンス番号 s を割り当て、 $\langle \text{PRE-PREPARE}, s, r \rangle$ メッセージを他のレプリカに送信
2. Prepare：レプリカが要求の順序に合意し、 $\langle \text{PREPARE}, s, r \rangle$ メッセージを全レプリカに送信
3. Commit：少なくとも $2f + 1$ の PREPARE メッセージを受信したレプリカは $\langle \text{COMMIT}, s, r \rangle$ メッセージを送信し、実行を確約
4. Reply： $2f + 1$ の COMMIT メッセージを受信したレプリカは要求を実行し、結果をクライアントに返送



PBFT の脅威モデル

PBFT の脅威モデルを考えてみよう。

PBFT の脅威モデル Λ_{PBFT}

- Corruption : **Byzantine** - レプリカは異なるメッセージを異なるレプリカに送信するなど、任意に振る舞うことができる
- Adaptivity : Adaptive - 敵対者はプロトコルの各フェーズで異なるレプリカを動的に腐敗させられる
- Computational Power : Polynomially Bounded - 多項式時間の計算に制限される（暗号署名が偽造不可能と仮定）
- Visibility : Private channels - 正直なレプリカ間の通信内容は秘密であり、内部状態も敵対者からは見えない
- Mobility : Mobile - 敵対者はプロトコルの各フェーズで異なるレプリカを動的に腐敗させられる

PBFT の正当性保証

$n \geq 3f + 1$ のとき (f は腐敗ノードの数、 n はレプリカの総数) :

- ・ **安全性** (Safety) : 正直なレプリカが同じシーケンス番号で異なる値をコミットすることはない
- ・ **活性** (Liveness) : すべてのクライアント要求は最終的に処理され応答が返される

を満たすことを証明できれば、PBFT は正当 (Correct) であると言える。

すなわち敵対者が脅威モデル Λ_{PBFT} の範囲においてどのような攻撃を行っても、Safety と Liveness を満たすことを証明できれば、PBFT は正当 (Correct) であると言える。

Question: なぜ $n \geq 3f + 1$ のとき Safety が満たされるのか？ PBFT がセキュアであることを説明してみよう！

仮定: 二つの異なる値 v と v' が同じシーケンス番号 s でコミットされたと仮定する。

Lemma

各値がコミットされるためには、少なくとも $2f + 1$ 個のレプリカから *PREPARE* メッセージが必要である。 $(3f + 1$ 個のレプリカのうち、腐敗したレプリカは最大 f 個)

- ・ 値 v がコミットされるには少なくとも $2f + 1$ 個のレプリカ群 $\mathcal{P}$ からの *PREPARE* メッセージが必要
- ・ 同様に、値 v' がコミットされるには少なくとも $2f + 1$ 個のレプリカ群 $\mathcal{Q}$ からの *PREPARE* メッセージが必要
- ・ 合計 $n \leq 3f + 1$ レプリカのうち、悪意あるレプリカは最大 f 個
- ・ $|\mathcal{P} \cap \mathcal{Q}| \geq 2f + 1 + 2f + 1 - n \geq 4f + 2 - (3f + 1) = f + 1$
- ・ つまり、少なくとも $f + 1$ 個の**正直なレプリカ**が両方の値 v と v' について *PREPARE* メッセージを送信したことになる
- ・ しかし、許容する腐敗レプリカは最大で f 個であって、正直なレプリカは同じシーケンス番号に対して複数の値に *PREPARE* を送信しない（プロトコルの定義により）
- ・ これは矛盾であり、したがって仮定は誤り

複雑化したプロトコルの正当性証明

ちょっとお題が変わって、複雑なプロトコルの証明について考えてみよう。

PBFT のようなシンプルなプロトコルはレアケース

- ・ PBFT のようなシンプルなプロトコルはレアケース
- ・ プロトコル設計では、既存のプロトコル上に新しいプロトコルを構築することが一般的である¹⁰

複雑なプロトコル

複数のプロトコル $\pi_1, \pi_2, \dots, \pi_n$ があったとき、それらを組み合わせたプロトコル $\Pi^{\pi_1, \pi_2, \dots, \pi_n}$ を複雑なプロトコルと呼ぶ。

Motivation：複数のプロトコル $\Pi^{\pi_1, \pi_2, \dots, \pi_n}$ の正当性保証（とりわけ Safety）はどう行うか？

¹⁰例えば、PBFT を使用する Hyperledger Fabric 上に新たなアプリケーションを構築

Universal Composability Framework

Universal Composability を用いてプロトコルの正当性証明を行う。

Universal Composability (UC)

Universal Composability は、セキュリティ分析において考慮される攻撃の範囲と限界を明示的に定義する。明示的な脅威モデリングが不可欠である。

。

これにより、複雑なシステムの分析を、より単純な構成要素の分析に還元できる。

parapappapa... プロトコルには任意の入力を受け取り、出力機能が存在する。¹¹

¹¹PBFT では、クライアントからの入力を受け取り、 $2f + 1$ 個のレプリカの出力を返す。期待する写像としては入力と出力が同一な恒等写像である。

理想世界 (Ideal World)

- ・ プロトコルのインターフェースを定義し理想となる入力と出力の写像を定義する。これを理想機能 $\mathcal{F}$ という。
- ・ 理想世界で敵対者を模倣するエンティティのシミュレータ Sim が存在する。
- ・ シミュレータ Sim は、理想機能 $\mathcal{F}$ を呼び出す

現実世界 (Real World)

- ・ インターフェースにそって実際の手続きと計算を定義する。これをプロトコル Π という。
- ・ プロトコル Π は各エンティティによって実行され、敵対者 $\mathcal{A}$ の攻撃に晒される
- ・ 敵対者は腐敗したエンティティを制御し、プロトコルの実行を妨害しようとする
- ・ 現実世界では、プロトコルの正当性は自明ではない (自明を示すためのするための証明だからね！)

Universal Composability Framework (続き)

環境 $\mathcal{Z}$

- ・ プロトコル以外 (外部) のすべてのシステム (ユーザー、他のプロトコル等) を表現する
- ・ 環境は、理想世界のシミュレータと現実世界のエンティティと敵対者の両者に入力を提供し、出力を受け取る (対話)
- ・ 環境は出力から理想世界と現実世界の区別がつかないかをチェックする

プロトコル Π が正当である定義

脅威モデル Λ における任意の敵対者 $\mathcal{A}$ に対して、対応するシミュレータ $\mathcal{S}$ が理想世界に存在し、どんな環境 $\mathcal{Z}$ も以下を区別できないこと：

- ・ 実際のプロトコル Π と敵対者 $\mathcal{A}$ との対話
- ・ 理想機能 $\mathcal{F}$ とシミュレータ $\mathcal{S}$ との対話

難しく説明したけど、要件に沿っていることを数理的、論理的に示そうねということです。

何が嬉しいのか？

- ・ ネットワークモデル：非同期か同期か、部分同期（通信遅延に上限がある）か
- ・ 敵対者モデル：敵対者はどのように振る舞うか
- ・ 腐敗ノードの数：攻撃者が制御できるエンティティの数の条件 ($n \geq 3f + 1$ など)

Question: 実世界で動かす上で考えるべき脅威、仮定はこれだけか？

本当に仮定はこれだけでいいのか？

ここまでで用いた仮定は以下の通りである：

- ・ ネットワークモデル：非同期か同期か、部分同期（通信遅延に上限がある）か
- ・ 敵対者モデル：敵対者はどのように振る舞うか
- ・ 腐敗ノードの数：攻撃者が制御できるエンティティの数の条件 ($n \geq 3f + 1$ など)

Question: 実世界で動かす上で考えるべき脅威、仮定はこれだけか？

これだけではすべてのプロトコルに Sybil Attack が適用できてしまう。

Sybil Attack

単一のエンティティが複数のエンティティを模倣し、システム内で不当な影響力を得る攻撃である。¹²

PBFT では $n \geq 3f + 1$ の条件がある。 n はノードの数、 f は敵対者の数である。これは各レプリカが一意に識別化であり、メッセージの送信元に偽りが無いことを暗黙の前提においている敵対者が単一のエンティティ（敵対者）が複数のエンティティとして振る舞えることを許すと、条件が破綻する。^a

^aCorruption Model の Byzantine に一定の妥協を許している。これはいいのか？

¹² 1 人のエンティティが山田花子と山田次郎の二つの役を演じているが、他のエンティティは山田花子と山田次郎が同一のエンティティであるかどうかを判断できない。

メッセージの送信元に偽りがないことを検証するためには、メッセージにデジタル署名を付与し、デジタル署名を検証する必要がある。

デジタル署名

数学的な関係性がある公開鍵 (verification key) pk と秘密鍵 (signing key) sk のペアを用いて、メッセージの送信元を検証する。

- ・ メッセージ m をデジタル署名する： $\sigma \leftarrow \text{SIGN}(sk, m)$
- ・ メッセージ m と署名 σ を検証する： $\{0, 1\} \leftarrow \text{VERIFY}(pk, m, \sigma)$ where 1 if m is valid, 0 otherwise

具体的なデジタル署名スキームとしては、RSA、ECDSA、EdDSA、Schnorr 署名などがある。

メッセージの真正性の検証

エンティティ $\mathcal{P}$ がメッセージ m をエンティティの $\mathcal{Q}$ に送付したとする。エンティティ $\mathcal{Q}$ はメッセージ m を確かに $\mathcal{P}$ から受け取ったことを検証する必要がある。

- ・ エンティティ $\mathcal{P}$ がメッセージ m に対するデジタル署名 σ を公開鍵 $pk_{\mathcal{P}}$ に対応する秘密鍵 $sk_{\mathcal{P}}$ を用いて生成する。
- ・ $\mathcal{P}$ は (m, σ) を $\mathcal{Q}$ に送付する。
- ・ $\mathcal{Q}$ は受け取った (m, σ) を検証する： $\text{VERIFY}(pk_{\mathcal{P}}, m, \sigma) \stackrel{?}{=} 1$

検証の正当性確保に必要な仮定: $\mathcal{Q}$ は $\mathcal{P}$ の公開鍵 $pk_{\mathcal{P}}$ を知っている。

Question: これだけでよいか？

Answer: 不十分。“デジタル署名で送信元を区別できる $\Leftrightarrow$ エンティティを区別できる”という命題は必ずしも成立しないからである。

デジタル署名はメッセージの送信者を区別できるが、エンティティと公開鍵の一対一対応が仮定されなければ、検証の正当性は保証されない。

- ・ 単一のエンティティが複数の公開鍵を生成し複数のエンティティとして振る舞える
- ・ エンティティと公開鍵の一対一対応を保証するためには Key Management System¹³が必要。KMS は一対一対応の検証する¹⁴

¹³Key Management System (KMS) は、エンティティと公開鍵の一対一対応を保証するシステムである。Public Key Infrastructure (PKI) は Key Management System の一種である。

¹⁴検証は二つある。第一にあるエンティティが自分は山田花子と主張したが、本当に山田花子であるかどうかを検証する。第二にエンティティ群と公開鍵の写像を定義すると、その関係性が全単射であることを確認する。確認後、KMS は紐付きが有効であることを示す署名 (=証明書) を発行する。利用者は KMS を信頼することで、この検証を署名の検証に置き換えることができる。

しかし、KMS には以下の問題がある：

- ・ 認証局の存在を許す = 信頼できる第三者の存在を仮定する
- ・ 単一障害点とスケーラビリティの問題が生じる

ほかにも Proof-of-Work：新たな識別子の作成に計算資源を要求する研究もある。

- ・ 分散システムの文脈でプロトコルを俯瞰すると、分散システムの魅力や効力を最大限発揮できないボトルネック（暗黙、非自明な仮定）が存在する。それは必ずしも学術論文に書かれているとは限らない。

どうやったらインパクトのある問題を見つけるか？

- ・ 運用を片手に持つ、ということは、理論の中で議論されたプロトコルの解釈方法を多様化できる力があることと等しい。
- ・ すなわちそのプロトコルが置かれる状況（提案手法の論理を支える仮定^a）を変えるとボトルネックが無視できるか、できないかを判断できる。
- ・ そのような探求がインパクトがあり、明確な Problem Statement に役立つと moz は信じている。

^a例えば、敵対者モデル、ネットワーク、タイミングモデル

今回は理論的な視点を提供したが、ぜひ運用視点を他の kG から聞くことで、自身の研究（分野）に新たな解釈をもたらすかもしれない。そのような解釈を皆で有機的に生み出し、共有し、高め合う全体講義になればと願っている。

- <https://www.cl.cam.ac.uk/teaching/2122/ConcDisSys/dist-sys-handout.pdf>
- <https://www.bu.edu/macsf/files/2016/03/2016-03-18-uc-tutorial-slides.pdf>